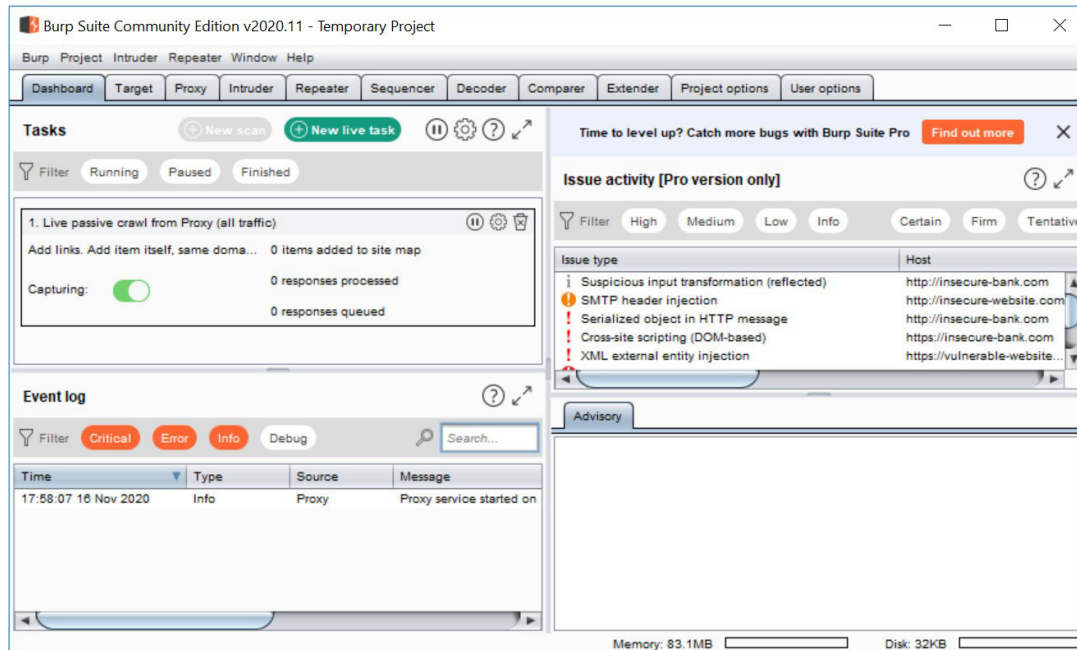


Fuzzing with Burp Suite

Overview



Burp Suite is a commercial cybersecurity tool by the company PortSwigger. Similarly, IS students should be familiar with this tool, but for the benefit of SE students, this lab will introduce how to use Burp Suite, specifically the free community edition for performing fuzz testing on a web application.

Outcomes

Upon completion of this lab, you should be able to:

- Perform fuzz testing on an intentionally vulnerable web application using Burp Suite
- Use Burp Suite to perform fuzz testing for your team project

1: Pre-requisite

Burp Suite Community Edition

Download and install Burp Suite Community Edition from <https://portswigger.net/burp/communitydownload>.

Burp Suite Intruder Payloads

To assist you in performing fuzz testing, you may clone the Burp Suite Intruder Payloads from <https://github.com/1N3/IntruderPayloads> . (Note: You may encounter error if using Windows to download, but it works fine if using Linux.)

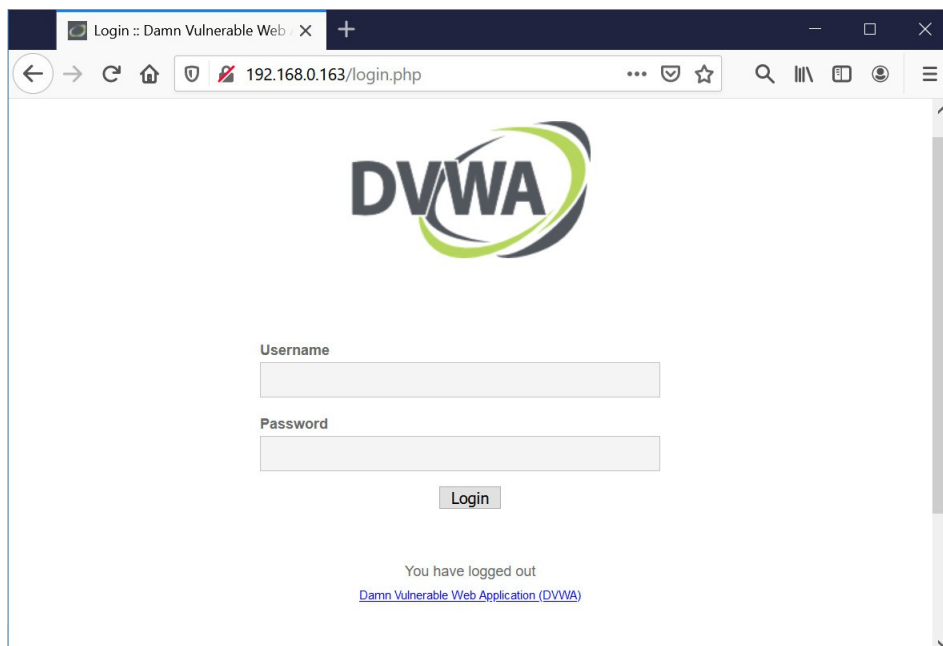
Damn Vulnerable Web Application (DVWA)

Reuse your locally hosted DVWA from Lab X10a.

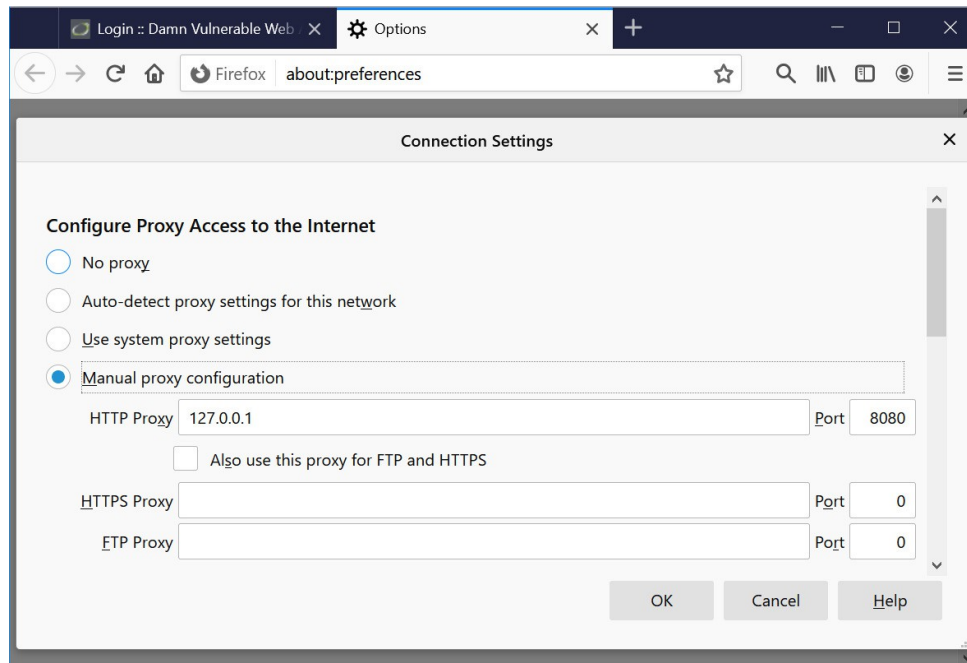
2: Performing Fuzz Testing on Web Application

Configure Browser with Proxy

Start a web browser to visit your locally hosted DVWA as shown. (Note: Due to the need for Burp Suite to intercept and proxy the communications between your browser and DVWA later, you will need to use the IP address of your machine instead of localhost or 127.0.0.1 in the URL.)



Next, configure your browser to use local proxy at port 8080, assuming that your Burp Suite is running locally at default port 8080. An example of configuring Firefox is shown:

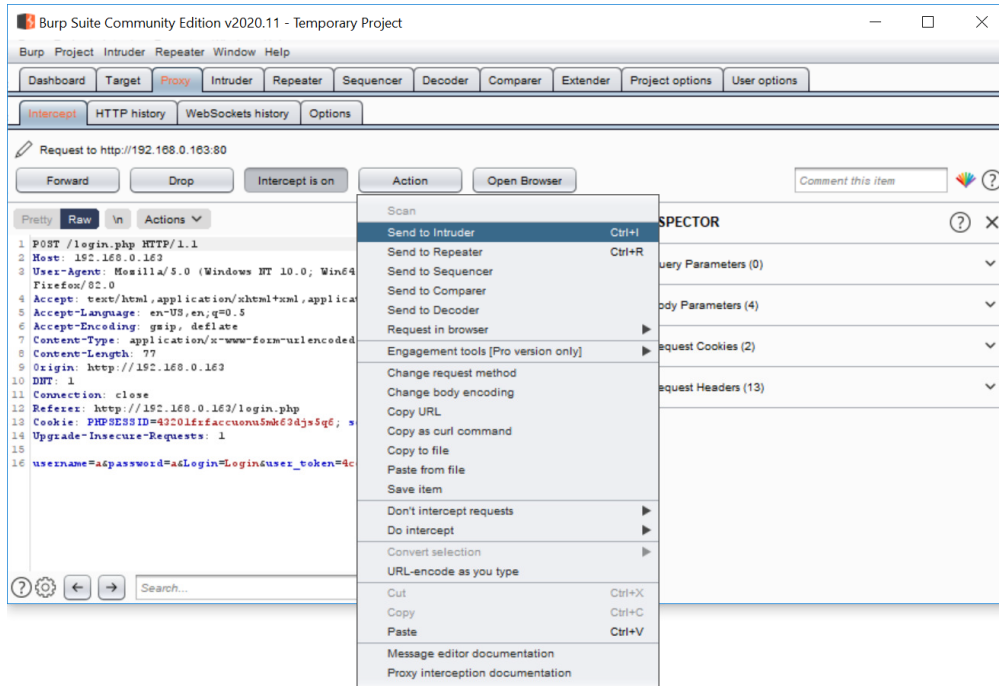


Perform Fuzz Testing with Burp Suite

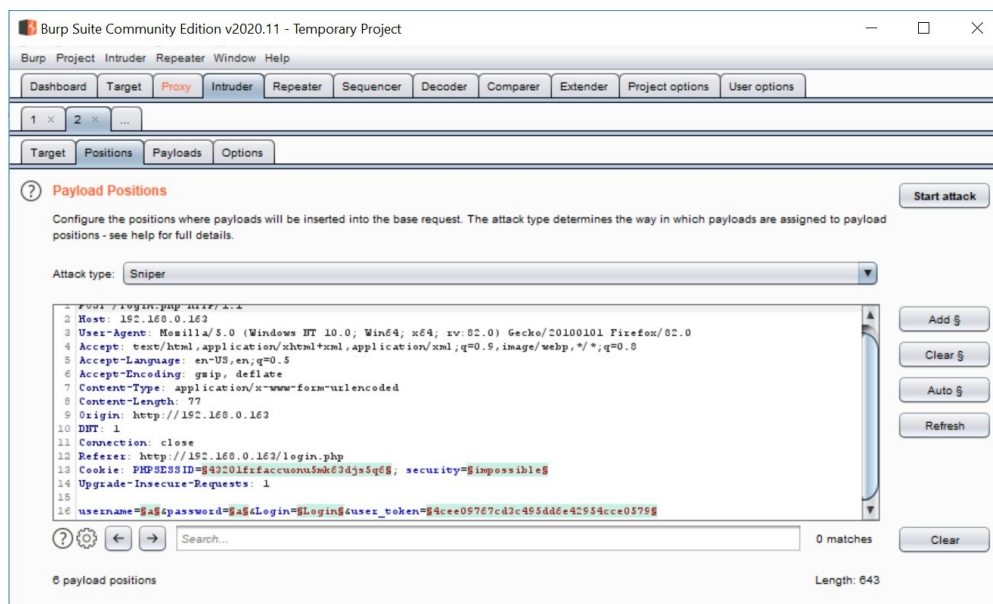
If you have not started Burp Suite, run it now to listen at default port 8080 corresponding to the proxy port you have configured at the browser.

Go to your browser showing the DVWA login page, enter any Username and Password, e.g. 'a' and 'a' respectively, and click the Login button which will now send the HTTP Request to the Burp Suite acting as the proxy.

Go back to the Burp Suite, click the 'Action' drop-down button and select 'Send to Intruder' as shown:

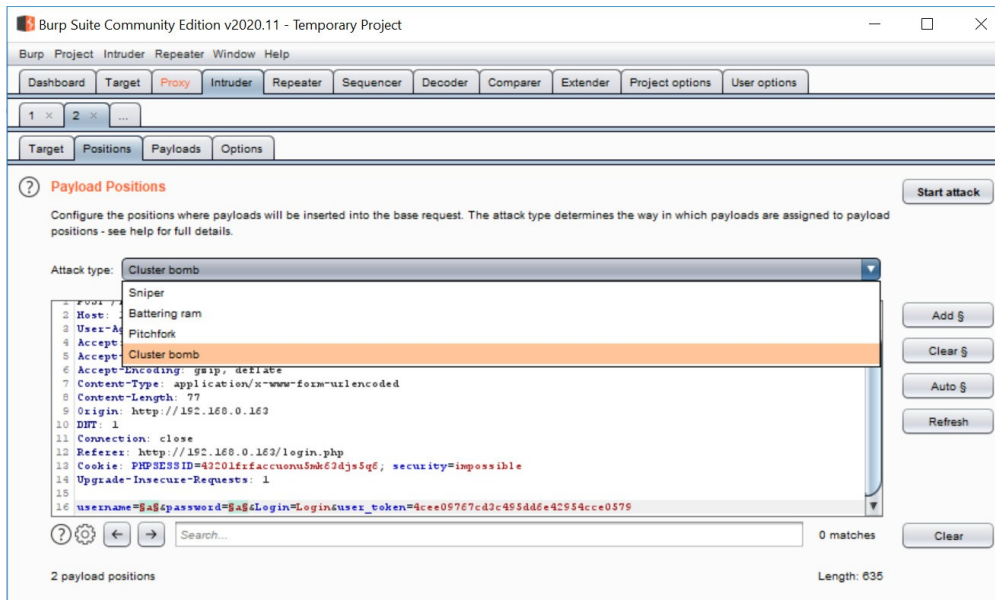


Next, select the 'Intruder' tab and within it, the 'Position' tab which will show you the highlighted input fields on the HTTP Request where fuzzing may be possible.

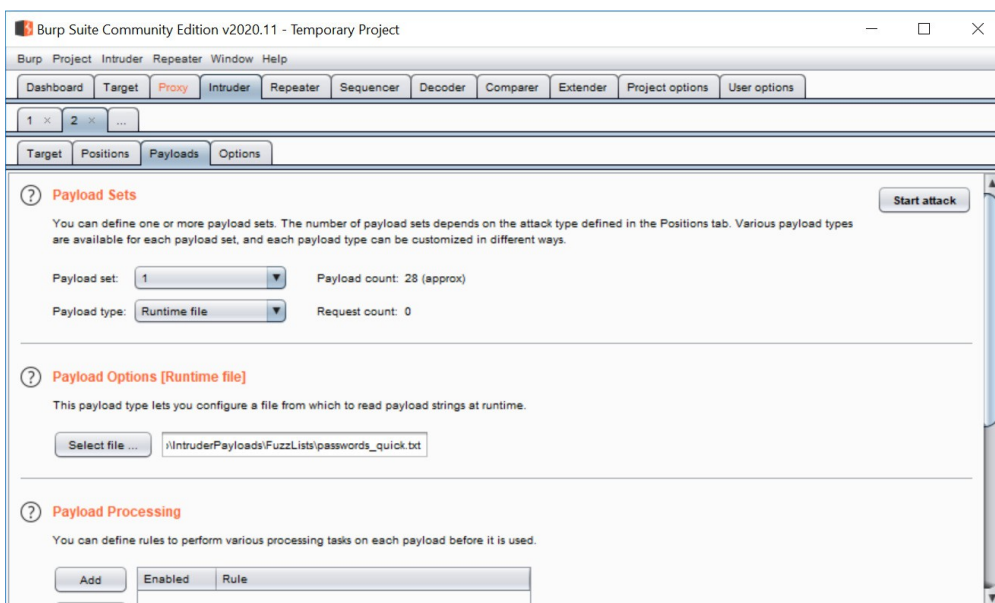


For this lab, we will try fuzzing on username and password input fields only. So clear the rest leaving only \$a\$ corresponding to username and password input fields highlighted. (You may do it by first clicking the 'Clear \$' button to clear all, then highlight the \$a\$ corresponding to username and click the 'Add \$' button. Do the same for the \$a\$ corresponding to the password input field.)

Burp Suite offers four different attack types which are explained at <https://portswigger.net/burp/documentation/desktop/tools/intruder/positions>. For this lab, we'll try Cluster bomb.

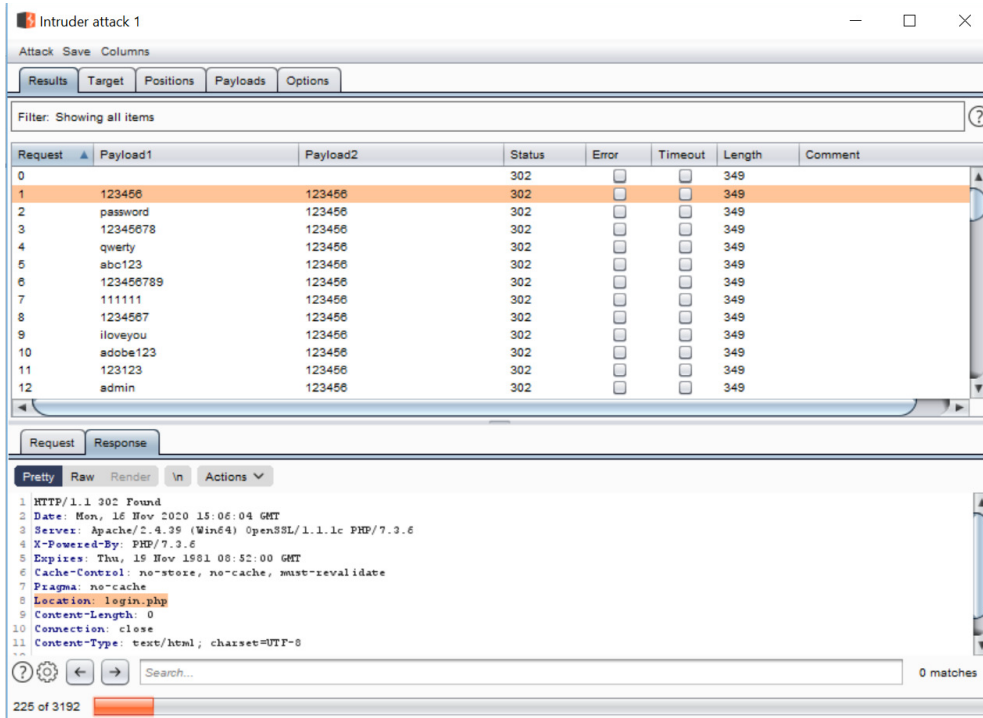


Next, go to the 'Payloads' tab to specify the payloads to use. For payload set 1 for username input field, we'll use the passwords_quick.txt file downloaded earlier from the Burp Suite Intruder Payloads, For simplicity, specify payload set 2 for password input field to use the same passwords_quick.txt file.

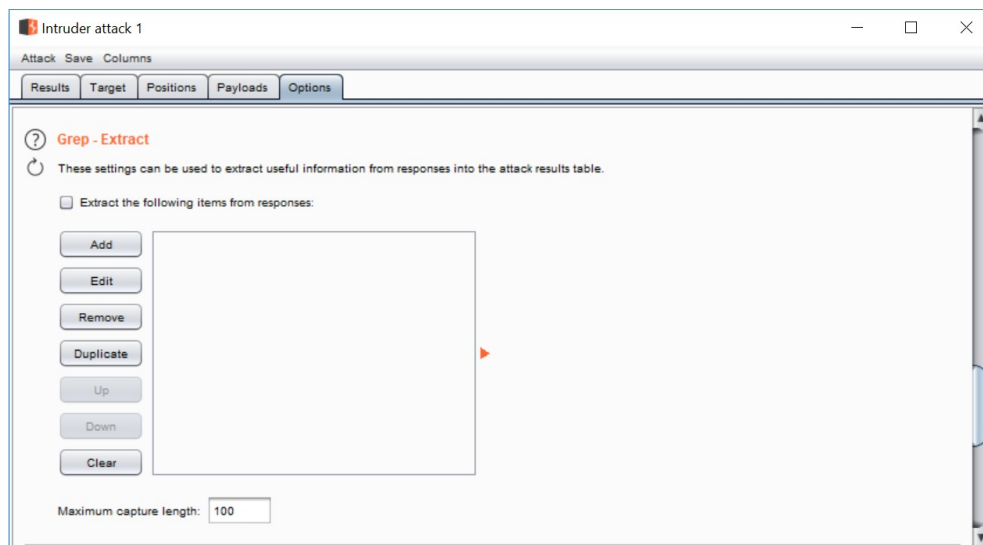


When ready, click the 'Start attack' button to commence fuzz testing. (It can take a long time to run depending on the size of your payloads.)

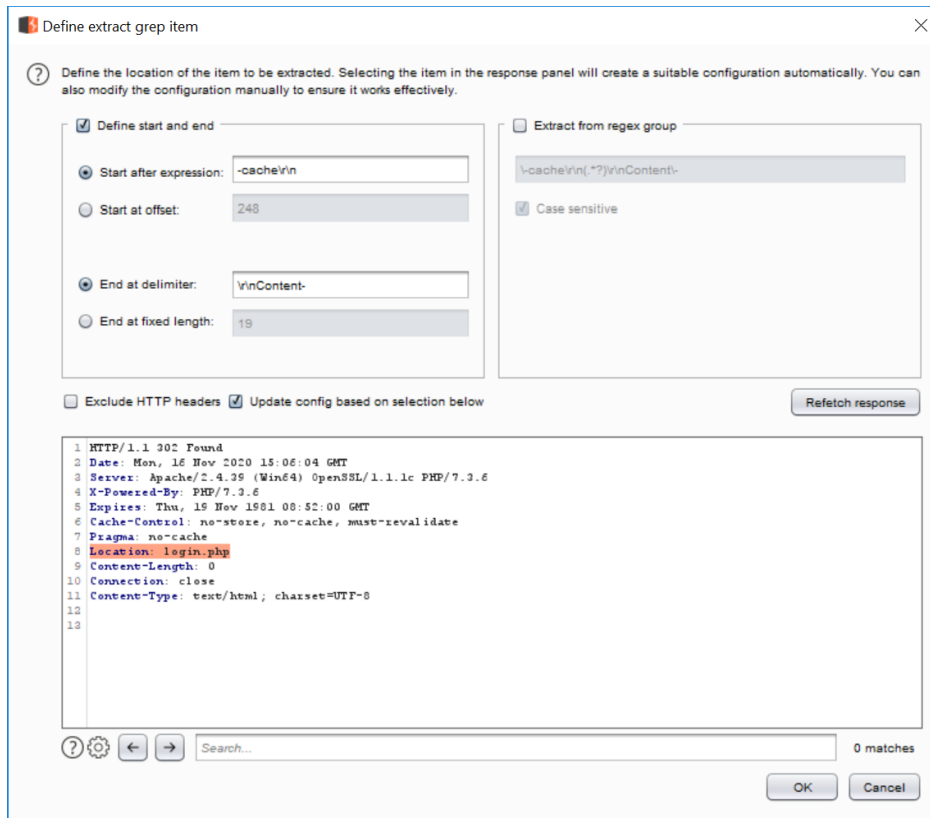
(Important: It's a criminal offence to fuzz a web site without authorised permission!)



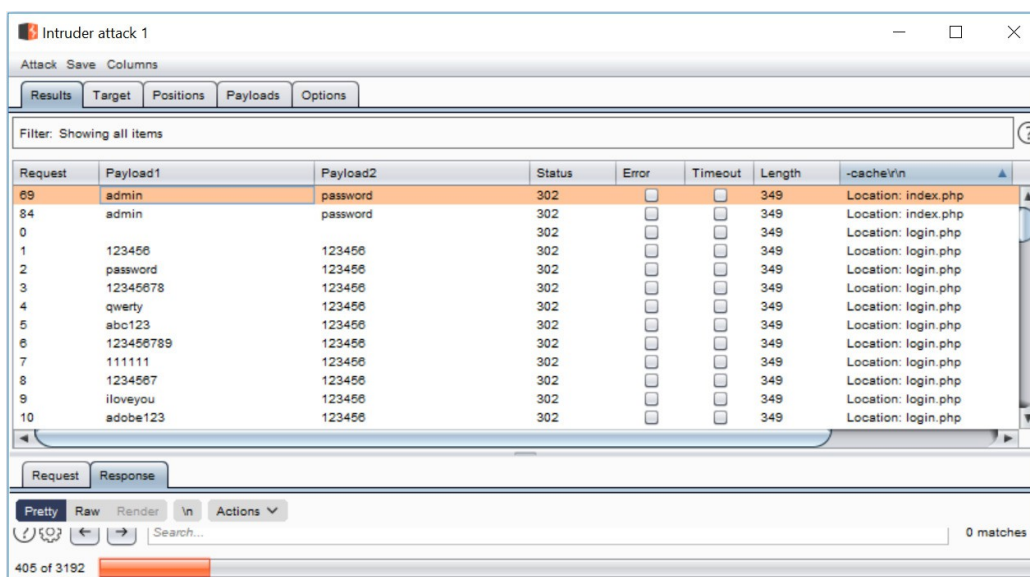
By analyzing the responses, we can deduce that if login fails, the 'Location:' field in the http response will re-direct back to login.php whereas if login passes, it is likely to re-direct to a different web page. So to facilitate identifying whether fuzzing is successful, go to 'Options' tab and scroll down to the section 'Grep – Extract' as shown:



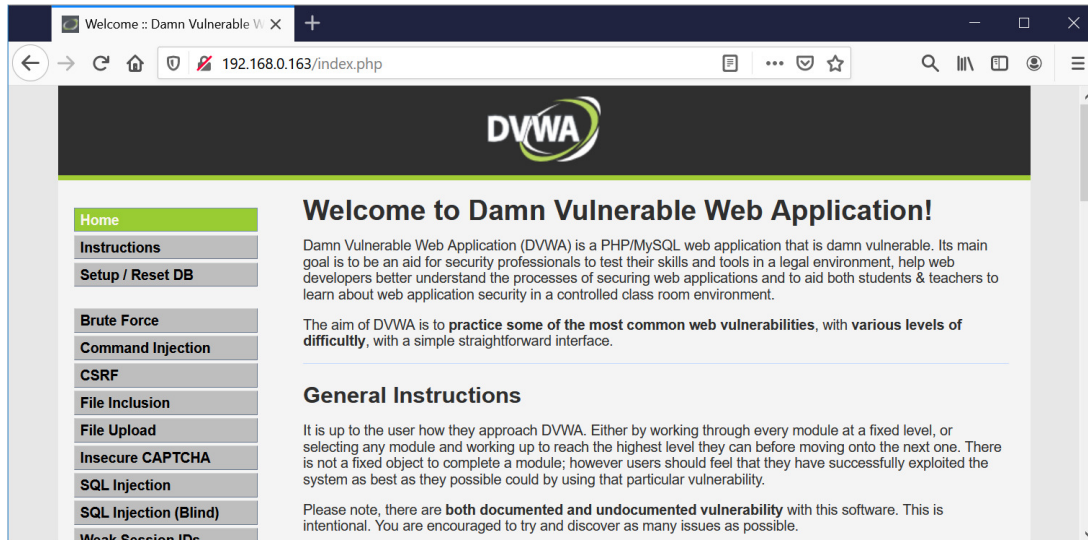
Click the 'Add' button which will pop-up a window. Select the item to extract which will be shown in the 'Results' tab and click the 'OK' button.



Return to the 'Results' tab and click the extracted field to sort the results. Notice that for username 'admin' with password equals 'password', it is re-directed to index.php.



To verify the result, go to your web browser, turn off the proxy, and try entering 'admin' and 'password'. Viola! You have login successfully!



There are a lot more features to try in Burp Suite and with various fuzz payloads. Explore around and enjoy performing fuzz testing in your team project!

3: References

Burp Suite Documentation <https://portswigger.net/burp/documentation>

END OF DOCUMENT